Projet Uncloak : état de l'art

Détection et neutralisation en temps réel des canaux de Command & Control (C2) furtifs (Cobalt Strike, Sliver) chiffrés en HTTPS avec jitter, par analyse statistique de cadence temporelle et corrélation processus (PID)

Oussama Belhane et Otman Saadouni

Synthèse de 11 articles scientifiques : titre, source, résumé, points forts et limites. Document du 2 novembre 2026.

Méthode et réserves

Les articles ont été repérés par recherche sur arXiv, IEEE Xplore, Springer et les sites des conférences. Les résumés sont établis à partir des résumés officiels et d'extraits en ligne ; tous les textes complets n'ont pas été lus. Les rubriques « Limites » combinent des limites annoncées par les auteurs et des limites par rapport aux objectifs d'Uncloak, notamment l'absence de corrélation processus et de réponse active. Les passages à vérifier dans le texte complet sont signalés. Aucun article scientifique recevable n'a été trouvé pour l'axe 5 (neutralisation de connexions TCP) ; il est traité en dernière section.

Vue d'ensemble

N°	Axe	Article (titre court)	Année
1	Beaconing	Ramos & Wang : ML sur Cobalt Strike chiffré	2022
2	Beaconing	Détection de beaconing par métadonnées, SCADA/ICS	2026
3	Beaconing	MORTON : routines malveillantes dans le DNS	2020
4	TLS	JA4+ pour la détection de malwares	2024
5	TLS	Identification précoce de services HTTPS	2020
6	TLS	PETNet : Cobalt Strike HTTPS	2024
7	Hôte-réseau	zeek-osquery	2020
8	Hôte-réseau	DefendCLI	2025
9	ML / CTU-13	Striking Back at Cobalt	2025
10	ML / CTU-13	Botnet Detection on CTU-13 (modèles légers)	2026
11	ML / CTU-13	XG-BoT	2022

Axe 1 : Détection statistique du beaconing et du jitter

1. A Machine Learning Based Approach to Detect Stealthy Cobalt Strike C&C Activities from Encrypted Network Traffic

Source	F. M. Ramos et X. Wang, George Mason University. Conférence MLN 2022 (Machine Learning for Networking). https://cs.gmu.edu/~xwangc/Publications/MLN2022-CobaltStrikeMLDetect.pdf
Résumé	Les auteurs détectent le trafic C&C de Cobalt Strike chiffré sans lire le contenu des paquets. Ils construisent des features sur le timing des paquets et la durée des flux, que le chiffrement ne modifie pas. Cinq algorithmes de ML sont testés sur du trafic Cobalt Strike réel issu de cyberattaques, mêlé à du trafic normal.
Points forts	Fonctionne sur du trafic chiffré, sans déchiffrement ni inspection de payload. Validé sur des traces réelles et non seulement simulées. Rejoint directement l'idée d'Uncloak : exploiter la cadence temporelle.
Limites	Le meilleur modèle (random forest) détecte environ la moitié des traces réelles, avec 1,4 % de faux positifs : le taux de détection est insuffisant et les faux positifs pèsent à grande échelle. Détection hors ligne, sans lien avec le processus émetteur ni action de réponse.

2. Beaconing detection via timing-based flow metadata analysis: implications for SCADA/ICS

Source	Springer, 2026 (DOI 10.1007/s10207-026-01335-w). Auteurs non relevés lors de la recherche. https://link.springer.com/article/10.1007/s10207-026-01335-w
Résumé	Méthode légère, indépendante du contenu, qui combine l'analyse de périodicité par coefficient de variation (CV) et une Isolation Forest non supervisée pour repérer les communications C2 périodiques à faible jitter. Elle est évaluée sur du trafic SCADA généré en laboratoire, mêlant navigation web humaine et balises C2.
Points forts	N'utilise que des métadonnées de flux : compatible avec le chiffrement. Approche non supervisée, légère et simple à expliquer (seuil de CV, score d'anomalie). Directement transposable à l'analyse de cadence d'Uncloak.
Limites	Évaluation sur du trafic de laboratoire dans un contexte SCADA/ICS, donc généralisation à un réseau d'entreprise non démontrée. Cible surtout le faible jitter (seuil de CV inférieur ou égal à 0,2) : un jitter élevé ou un profil malleable peut échapper à la méthode. Pas de corrélation avec le processus.

3. MORTON: Detection of Malicious Routines in Large-Scale DNS Traffic

Source	arXiv 2008.02003, 2020. https://arxiv.org/pdf/2008.02003
Résumé	MORTON détecte les routines malveillantes (beaconing et autres comportements répétitifs) dans le trafic DNS à grande échelle. Il s'appuie sur un réseau de neurones à trois couches cachées et construit une base de signaux non périodiques pour juger la significativité d'une périodicité. Il est comparé à Baywatch et WARP sur la précision, la robustesse au bruit et les performances.
Points forts	Traite explicitement la robustesse au bruit et le passage à l'échelle. Comparaison avec des méthodes de référence de détection de périodicité.
Limites	Limité au trafic DNS, alors qu'Uncloak vise HTTPS. Les expériences de beaconing rapportées utilisent des requêtes répétées à intervalle constant, ce qui évalue peu le cas du jitter aléatoire. Pas de lien avec l'hôte.

Axe 2 : Analyse du trafic chiffré et empreintes TLS

4. Experience Report: Using JA4+ Fingerprints for Malware Detection in Encrypted Traffic

Source	P. Matoušek, O. Ryšavý, I. Burgetová. 20th International Conference on Network and Service Management (CNSM 2024), Prague, IEEE, pp. 1-5. DOI 10.23919/CNSM62983.2024.10814358. https://ieeexplore.ieee.org/document/10814358
Résumé	Les auteurs évaluent l'efficacité des empreintes JA4+ (JA4, JA4S, JA4X), issues du handshake TLS, pour détecter des malwares dans le trafic chiffré. L'étude porte sur la création des empreintes, leur unicité entre familles de malwares et leur capacité à séparer applications malveillantes et bénignes.
Points forts	Détection sans déchiffrement, à faible coût, à partir d'éléments transmis en clair. Étude récente qui couvre les empreintes client, serveur et certificat.
Limites	Les empreintes peuvent se recouvrir entre malwares et applications légitimes, ce qui limite la fiabilité d'une empreinte seule. Un attaquant peut modifier ses paramètres TLS pour changer d'empreinte. Rapport court (5 pages) : analyse d'une démarche plutôt qu'un système complet.

5. Early Identification of Services in HTTPS Traffic

Source	W. M. Shbair, T. Cholez, J. François, I. Chrisment. arXiv 2008.08350, août 2020. https://arxiv.org/abs/2008.08350
Résumé	Méthode de ML qui identifie des services HTTPS sans déchiffrement, à partir de statistiques sur les paquets du handshake TLS et sur un petit nombre de paquets de données applicatives. Elle est évaluée sur un jeu de données ouvert et un prototype confirme l'identification précoce.
Points forts	Identification très tôt dans la session, donc utile pour une décision en temps réel. Aucun déchiffrement, ce qui préserve la vie privée. Évaluée sur des données ouvertes, reproductible.
Limites	Identifie des services HTTPS légitimes, pas du C2 : le cas du beaconing avec jitter n'est pas traité. Les paramètres du handshake peuvent être imités par un attaquant. Date de 2020.

6. PETNet: Plaintext-aware Encrypted Traffic Detection Network for identifying Cobalt Strike HTTPS traffics

Source	X. Yang, S. Ruan, Y. Yue, B. Sun. Computer Networks, janvier 2024 (Elsevier). DOI 10.1016/j.comnet.2023.110120. https://pure.bit.edu.cn/en/publications/petnet-plaintext-aware-encrypted-traffic-detection-network-for-id/
Résumé	Réseau de détection du trafic HTTPS de Cobalt Strike en trois modules : modélisation des méta-informations, encodage du contenu chiffré par un Transformer guidé par ces méta-informations, puis fusion et prédiction. Il vise à résister aux infrastructures variables et aux certificats déguisés qui trompent les méthodes existantes.
Points forts	Cible précisément Cobalt Strike en HTTPS. Capture plusieurs aspects du trafic et leurs relations, au-delà d'une empreinte unique. Robuste aux certificats déguisés.
Limites	Modèle profond (Transformer) coûteux et moins explicable, difficile à embarquer sur un hôte pour une détection en temps réel. Spécifique à Cobalt Strike : Sliver et autres frameworks ne sont pas couverts à ma connaissance. Classification du trafic, sans lien avec le processus ni réponse active.

Axe 3 : Corrélation hôte-réseau (NDR + EDR)

7. zeek-osquery: Host-Network Correlation for Advanced Monitoring and Intrusion Detection

Source	S. Haas, R. Sommer, M. Fischer (Universität Hamburg). arXiv 2002.04547, 2020. Version IFIP SEC 2020. https://arxiv.org/pdf/2002.04547
Résumé	Plateforme qui collecte, traite et corrèle des données d'hôte (osquery) et de réseau (Zeek) à grande échelle, pour attribuer chaque flux réseau à un processus et à un utilisateur. L'attribution repose sur la correspondance du 5-uplet du flux avec les sockets de l'hôte. Elle réussit pour 96,05 % des connexions TCP et 86,61 % de tous les flux.
Points forts	Référence directe pour le lien PID-connexion d'Uncloak. Fonctionne en quasi temps réel, passe à l'échelle avec le nombre d'hôtes et s'étend avec des scripts Zeek.
Limites	Attribution UDP d'environ 50 % : les sockets de courte durée sont manqués, notamment les requêtes DNS. Corrélation parfois vague (réutilisation de PID, parent/enfant après exec). Nécessite un agent osquery sur chaque hôte. Ne traite pas la détection de C2 ni la réponse.

8. DefendCLI: Command-Line Driven Attack Provenance Examination

Source	arXiv 2508.12553, août 2025 (v2 février 2026). UNSW Canberra et CSIRO Data61. https://arxiv.org/abs/2508.12553
Résumé	Travail sur les EDR fondés sur les graphes de provenance d'attaque. Les auteurs déploient un EDR de provenance sur des journaux d'audit du Microsoft Cyber Defense Operations Center, relèvent les difficultés rencontrées par les analystes et proposent une différenciation à trois niveaux : appels système inhabituels, lignes de commande suspectes, connexions externes rares.
Points forts	Validation sur des données d'audit réelles. Intègre les connexions externes rares dans la corrélation d'événements système, ce qui rejoint la corrélation système d'Uncloak. Rend les résultats de provenance plus exploitables.
Limites	Centré sur les lignes de commande et les graphes de provenance, pas sur l'analyse temporelle du trafic réseau ni sur le jitter. Dépend de journaux d'audit complets. Les auteurs soulignent eux-mêmes que l'adoption des EDR de provenance reste limitée.

Axe 4 : Machine learning pour la détection C2 et jeu de données CTU-13

9. Striking Back at Cobalt: Using Network Traffic Metadata to Detect Cobalt Strike Masquerading Command and Control Channels

Source	C. Parssegny, J. Mazel, O. Levillain, P. Chifflier. ARES 2025, LNCS 15992, Springer, pp. 163-185. arXiv 2506.08922. https://arxiv.org/abs/2506.08922
Résumé	Méthode de ML passive qui détecte le C2 Cobalt Strike, même masqué par des profils malleables imitant des services légitimes et chiffré, à partir des seules métadonnées réseau. Elle adapte le modèle utilisé au trafic observé (protocole, domaine) et reste explicable. Elle est validée sur des captures réelles.
Points forts	Article le plus proche du sujet : features simples et courantes, déploiement facile en production, adaptation du modèle au trafic, explicabilité. Publication récente et évaluée par des pairs.
Limites	Les résultats sont plus nuancés pour HTTP et HTTPS que pour les autres cas. Entraînement dépendant de captures de Cobalt Strike. Détection passive : pas de corrélation avec le processus ni de neutralisation.

10. Botnet Detection on CTU-13 Using Lightweight Machine Learning Models

Source	S. Gurappa, S. S. Iyengar, Y. Hariprasad, N. K. Chaudhary. arXiv 2605.23004. https://arxiv.org/pdf/2605.23004
Résumé	Étude comparative de modèles légers (régression logistique, arbre de décision, random forest) sur CTU-13, avec des features de flux interprétables. Le random forest atteint un ROC-AUC d'environ 0,97 et un PR-AUC d'environ 0,54 sous déséquilibre naturel des classes, en s'entraînant plus de 90 % plus vite que des CNN publiés.
Points forts	Modèles interprétables, rapides à entraîner et peu coûteux : adaptés à un contexte de détection en temps réel et à l'analyse forensique. Évalue honnêtement le déséquilibre des classes.
Limites	Un PR-AUC d'environ 0,54 signale un compromis précision/rappel médiocre. CTU-13 date de 2011 et ne contient pas les C2 modernes (Cobalt Strike, Sliver, jitter). Pas de corrélation hôte ni de réponse.

11. XG-BoT: An Explainable Deep Graph Neural Network for Botnet Detection and Forensics

Source	arXiv 2207.09088, 2022. Résumé établi d'après le titre, l'extrait de la revue de littérature et son tableau comparatif. https://arxiv.org/pdf/2207.09088
Résumé	Réseau de neurones sur graphes (grouped reversible GIN) qui détecte des bots à partir de graphes de communication, évalué sur CTU-13 et CAIDA. Il est présenté comme explicable et orienté forensique. L'article offre aussi un tableau comparatif utile de méthodes de détection de botnets sur CTU-13.
Points forts	Explicabilité et usage forensique. Le tableau comparatif donne une vue d'ensemble de l'état de l'art sur CTU-13.
Limites	Travaille sur des graphes de communication agrégés, peu adaptés à une décision par connexion en temps réel. Modèle profond plus lourd. CTU-13 est ancien. N'exploite pas la cadence temporelle fine du beaconing (point à vérifier dans le texte complet).

Axe 5 : Neutralisation et coupure de connexions TCP

Aucun article scientifique de la période 2019-2026 n'a été trouvé pour cet axe lors de cette recherche. L'article NDSS sur la détection de paquets RST forgés date de 2009 et sort de la période. Deux sources de littérature grise, non évaluées par des pairs, soulignent les limites de la coupure par RST et justifient une approche plus ciblée :

- Vectra AI, « TCP reset does not stop modern attacks » : conditions de course, challenge ACK activé par défaut sur de nombreux systèmes Linux, l'attaquant peut déjà avoir un accès établi.
https://docs.vectra.ai/operations/analyst-guidance/tcp-reset-does-not-stop-modern-attacks

- ExtraHop, « TCP resets and C2 » : l'hôte compromis relance simplement la connexion, et un proxy intermédiaire peut faire fermer la mauvaise connexion.
https://www.extrahop.com/blog/tcp-resets-rst-prevent-command-and-control-dos-attacks/

Références complémentaires

Brouillon IETF « TCP Provenance Identifier Option » (draft-liang-tcp-provenance-option, 2026) : propose d'encoder IP hôte et identifiant de processus dans une option TCP. Ce n'est pas un article évalué par des pairs ; à citer comme référence complémentaire uniquement.
https://datatracker.ietf.org/doc/draft-liang-tcp-provenance-option/

Liste des sources

[1] https://cs.gmu.edu/~xwangc/Publications/MLN2022-CobaltStrikeMLDetect.pdf
[2] https://link.springer.com/article/10.1007/s10207-026-01335-w
[3] https://arxiv.org/pdf/2008.02003
[4] https://ieeexplore.ieee.org/document/10814358
[5] https://arxiv.org/abs/2008.08350
[6] https://pure.bit.edu.cn/en/publications/petnet-plaintext-aware-encrypted-traffic-detection-network-for-id/
[7] https://arxiv.org/pdf/2002.04547
[8] https://arxiv.org/abs/2508.12553
[9] https://arxiv.org/abs/2506.08922
[10] https://arxiv.org/pdf/2605.23004
[11] https://arxiv.org/pdf/2207.09088